

INFORMATION
SECURITY

: Course Outline :

- Basic notions of confidentiality integrity
- Availability
- Authentication models
- Protection models,
- Security Kernels -
- Encryption
- Hashing & Digital Signature
- Audit
- Intrusion detection and response
- Database Security
- Hostbased and network-based security issues
- Operational security issues
- Physical security issue
- Personal security
- Policy formation and enforcement
- Access control
- Information flow
- Legal and Social issues
- Identification and Authentication in local and distributed system
- Classification & trust modeling
- Risk Assessment.

Lecture # 01 & 02 :-

Content :-

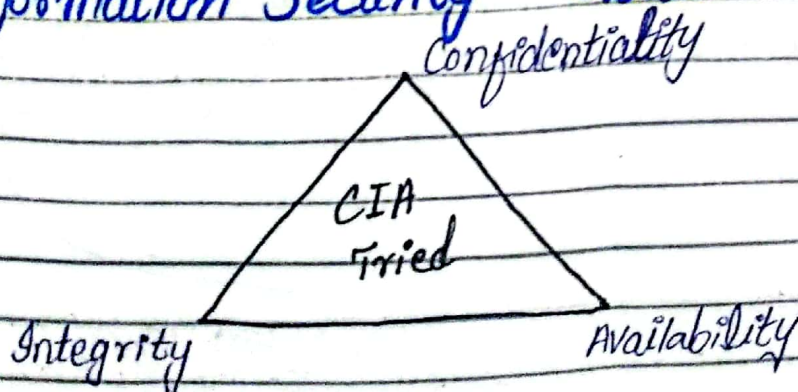
- ↳ Information Security
- ↳ Difference b/w IS/CS/NS
- ↳ Information Security Goals
- ↳ Information Security Principles
- ↳ Information Security Elements

Information Security :-

"The protection of information against unauthorized, disclosure, transfer, modification or destruction whether accidental or intentional."

"Unauthorized" means without permission
"disclosure" means reveal or uncover
"transfer" is to move
"modification" is change

Information Security Goals :-



{ also called building blocks of Information Security

Information Security Principles:-

1- Need to know:-

↳ Person should have ability to access data sufficient to perform primary job and no more.

2- Least Privilege:-

↳ Person should have ability to do task sufficient to perform primary job and no more.

3- Segregation of Duties:-

↳ Ensure that no person can assume two roles

- Organization
- Authorization
- Distribution
- Verification

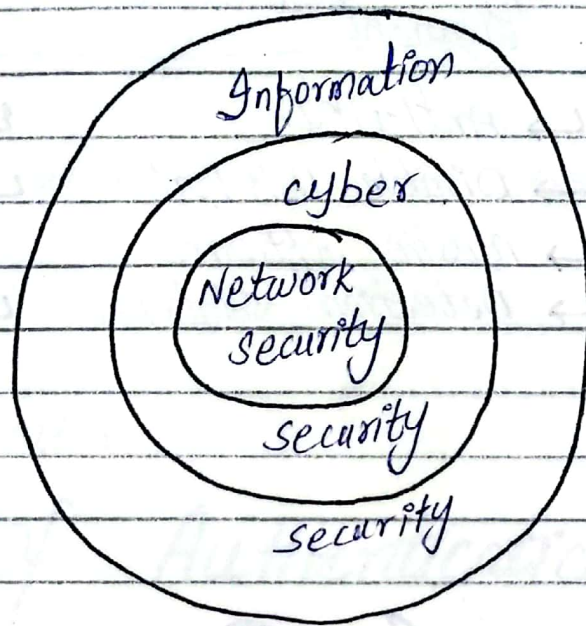
1- Privacy:-

↳ Personal/Private information is retained only when a true business need exists:

↳ Privacy is a liability - retain record for short time.

↳ Personal office should change permission as job change.

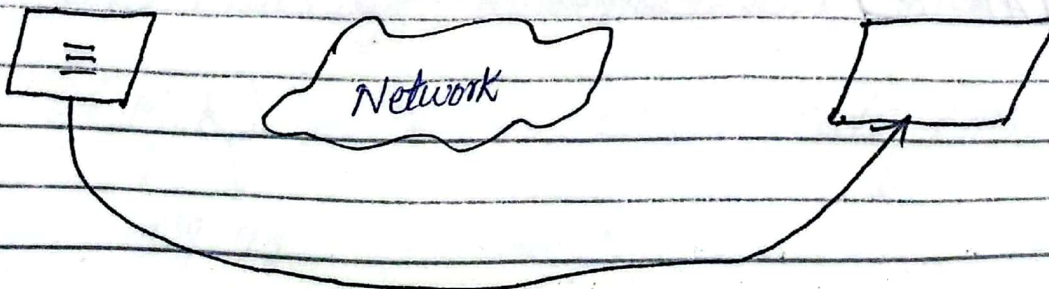
Information Security / Cyber Security / Network Security



Types of data:-

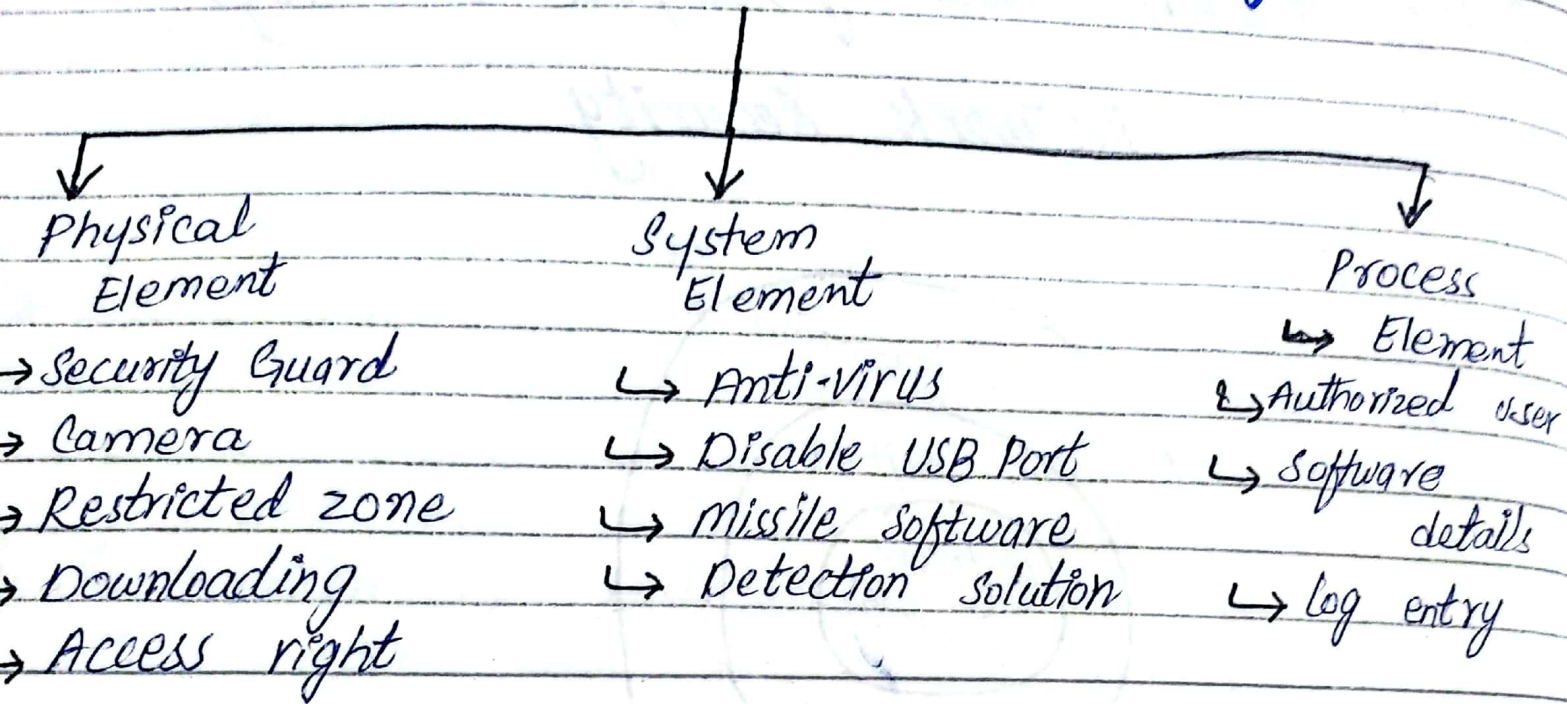
The information which we want to secure have two forms :-

- 1:- At rest
- 2:- In motion.



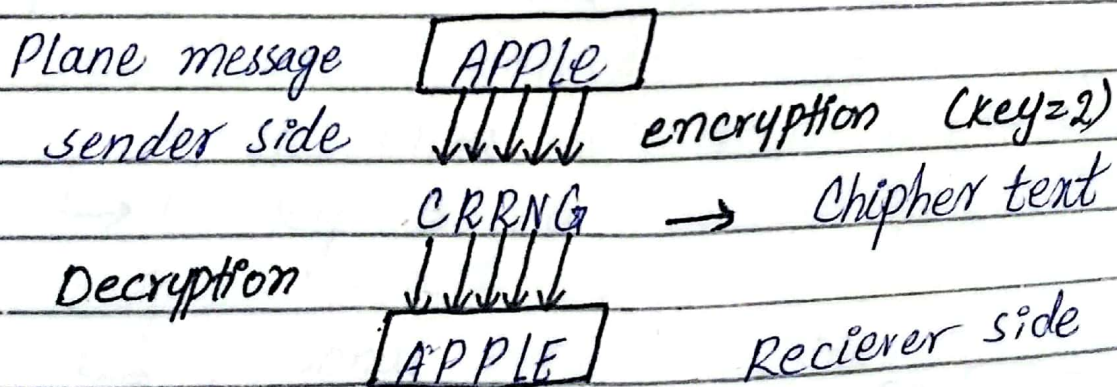
Data travel from one system by
use of any network

-: Elements of Information security :-



Lecture # 03:-

-: Encryption & Decryption :-



-: Authentication & its functions:-

↳ Authentication is verifying the user identity



↳ An Authenticator must be there to authenticate the message.

↳ There is a generator by authentication function.

↳ is a value.

Types of Authentication :-

modes functions

(i) message encryption:-

cipher text act as an Authenticator.

(ii) MAC (Message Authentication Code):-

$C(M, K) \Rightarrow$ fixed length code (MAC)

$\downarrow$	$\downarrow$	$\downarrow$	$\downarrow$	$\downarrow$
function	msg	key	compressed msg / gn less length	This will act as Authenticator here.

Example:-

1 MB $\rightarrow$ 1 KB
 $\hookrightarrow$ fixed length

We will have some authentication function and we apply on plain text along with the key which produce a fixed length code called MAC.

Hash function (H) :-

$\hookrightarrow$ Independent of key

$H(m) =$ fixed length code (hash code 'H')

hash $\leftarrow$ function $\downarrow$ msg $\leftarrow$ act as an authenticator.

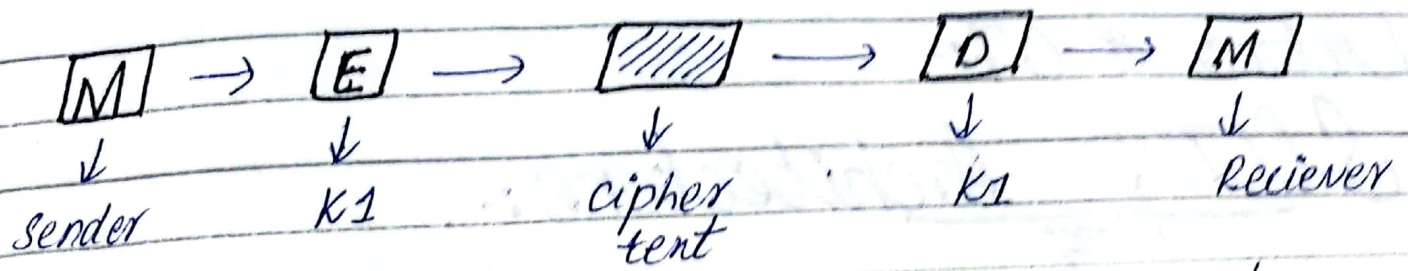
$\therefore$ Message Encryption :-

Encryption

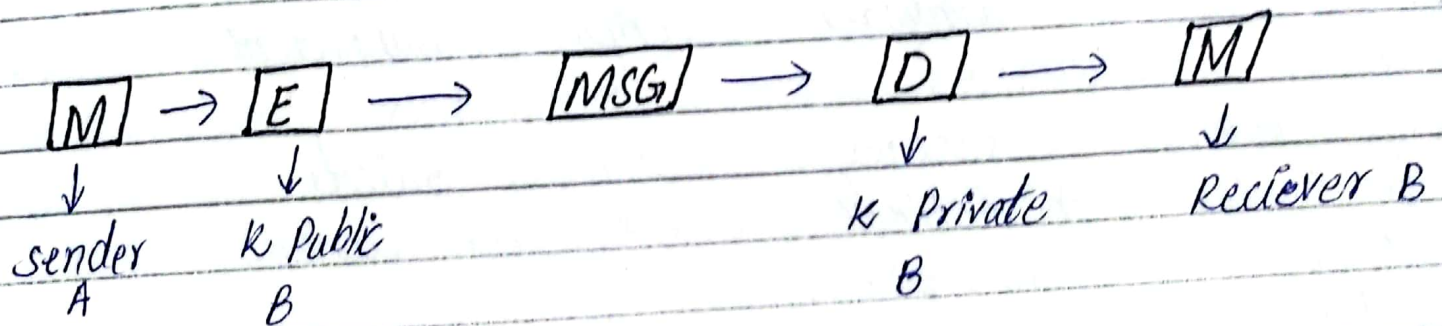
$\swarrow \searrow$

Symmetric
same key used.

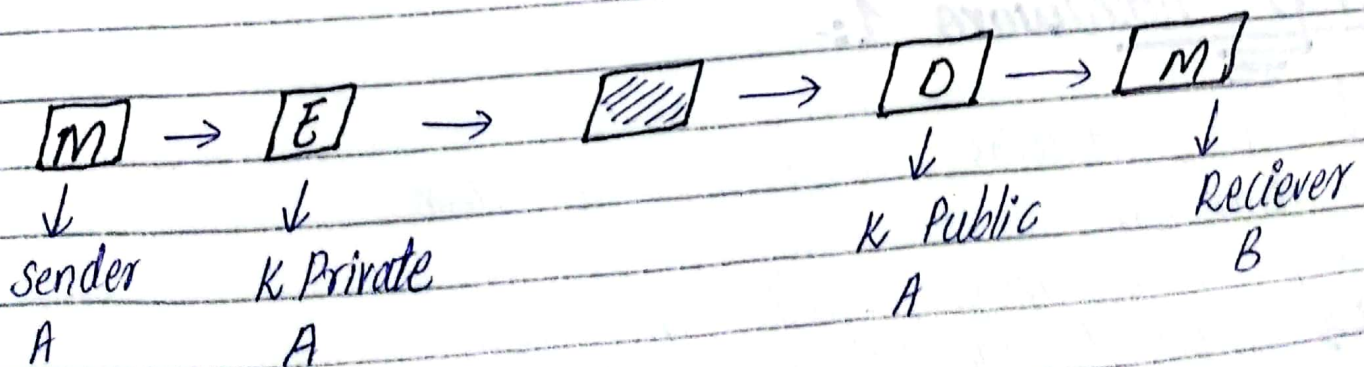
Asymmetric
Different key used.



Key K_1 shared only between sender and receiver only.



K Public B is read as Public key of B.



Lecture # 07:-

S-Comp Architecture:-

- Accesses to protected resources are mediated using an MLS policy.
 multics
- App request hardware description sufficient access resources.
- If granted, security kernel builds the descriptor (object + permission) and returns a reference.
- Isolation/temperproofing provided by ring-mechanism. Ring & transition are implemented in h/w.
- Verification was part of the process

Scomp Hardware 1:-

- Based on Multics design with two key changes.
 - Only four rings, all in h/w
 - Argument addressing mode prevents confused deputy problems.
- H/w include a security Protection module (SPM)
 - It mediate the main system bus

(peripheral & memory).
→ Virtual memory interface unit uses epm to convert b/w virtual & physical addresses.

Scmp Hardware 2:-

Each processor include a descriptor base root:-

- Reference memory & I/O descriptor.
- use for mediating memory and I/O References
- DMA is authorized on a per-transaction basis. (Data Manipulating Access) (DMA)
- I/O descriptor are built by kernel
- H/w does all authorization.
- Drivers are not parts of kernel.
 - more efficient & secure.

Basic Notions Of Confidentiality, Integrity and Availability:

CIA:-

Confidentiality:-

1) No unauthorized access:-

Unauthorized access nahi honi chiyee. Data ko internet py access kiya ja skta ha is se confidentiality lose nhi hoti confidentiality us waqt lose hoti ha jb koe ap k data ko read be kr sky or s usy smj b sky. is ka sb se best way Encryption or decryption ha.

2) Few methods to breach confidentiality (social engineering, password cracking, phishing, ~~an~~ spam, malware attack, unsecured network, & system).

3) Tool available to achieve confidentiality (Vera crypt, True crypt, x crypt etc).

Integrity:-

1. No modification of data.

Agar koe koi ko data bhi raha r ha

rasty ma koe unauthorized person us data ma change kr k reciever side py bhj dy. or reciever accept be kr dy.

- 2- Few methods to breach integrity (SQL injection, malware attacks, man-in-the-middle attacks, Data tempering, man-in-the middle attack)
- 3- Tools available to achieve integrity (Hash check, md5sum, sha1sum, Quick SFV)

Availability:-

1. Data unavailable.

Jb hm koi app se kuch order krty hain to sometime loading ho rahi hoti ha or ap dosri app use krny lgty hain is se user be km ho jaty hain, jo hmy data ko available rakhna hota ha. data should be 24/7 available ho.

- 2- Few methods to breach Availability (DDos (Distributed Denial of service) attack, malware attack, Natural disaster, Human error (ap ki khud ki waja ght data chla jaye) or system failure.

3. Tools available to achieve availability. cloud-based (Firewalls, IDS/IPS, Regular backup, solutions).

-: Authentication Model:-

Authentication:-

Authentication is the process of identifying users that access to the system, network or device.

Access controls often determines users identity according to credential like password or username.

Other authentication technologies like Biometric & authentication apps are used to authenticate user identity.

Why user authentication important:-

User authentication is method that keeps unauthorized user from accessing sensitive information.

For example,

User A has access only to relevant info and cannot see sensitive information of user B.

Cybercriminals ap k system ko access kr skty hain, ap ki information steal ho skti ha agr ap user authentication secure nahi ho gi. ☹️
Data breaches companies like Adobe,

Equifax and Yahoo faced are example of what happen when organization fail to secure their user authentication.

Authentication models/methods:-

1. Password-based authentication:-

Passwords are most common methods of authentication. It can in form of letters, numbers, or special characters. To protect yourself, you need to create a strong password that include combination of all possible options (numbers, letters etc)

Sometimes hm apni asani k liye different sites py aik hi password dal laty hain asy nhi krna chiyee. Different password rakhy. Nahi to hacker ap ka password hack kr skty.

It is weaknesses based method.

2. Multi-Factor Authentication:-

MFA is an authentication method that require two or more independent ways to identify the user.

Example include code generated from user's smartphone, (Email py ata).

fingerprints, or facial recognition.
MFA authentication method & technologies increases the confidence of users by adding multiple layers of security.
It is good defence against accounts hacks.

Lekin drawback yeh ha k agr ap ka phone yeh sim card gum ho jata to ap authentication code generate nahi kr skty.

3- Certificate-based authentication:-

certificate-based authentication technologies identifying users, machines or devices by user digital certificates.

A digital certificate is an electronic document based on the idea of driver's license or a passport.

certificate contain the digital identity of a user including a public key, and a digital signature of certification authority.

User provide digital certificate when they sign in to the server.

Phr server verify kry ga dono cheez.

server isy cryptography k zariye confirm
kry ga.

4. Biometric authentication:-

It is best authentication method.
Biometric authentication can control physical
access. when installed on gates & doors.
Biometric multi-factor authentication ma
be use ho skti ha.

Biometric authentication are used by
consumers, Govt & private corporations
including airports, military bases, hospital etc.
Common biometric authentication methods include.

Face recognition:-

Finger-Print scanners:-

Voice identification.

Eye scanner (Iris matches).

5. Token-based Authentication:-

Token-based authentication technologies enables
users to enter their credential once &
receive a unique encrypted string of
random character in exchange.

You can use token to access protected
system instead of entering your
credential all over again.

-: Protection model:

Protection:-

- No Protection:-

Sensitive procedures are run at separate time.

- Isolation:-

Each process operates separately from other processes with no sharing or communication.

- Share all or share nothing
Owner of an object declare it public or private.

- share via access limitation:-

OS checks the permissibility of each access by a specific to a specific object.

Radra office ma hr user ko permission di jati ha ap data ko insert yeh update kr skty ho.

OS acts as a guard.

- Limit use of an object:-

Kai b object ko ap limitation k mutabik use kr skty ho.

Protection of memory:-

→ security

→ Ensure correct function of various processes that are active.

Current info ap ko provide krny).

User-Oriented Access control:-

• Log On

→ Require both a user identifier and password.

→ system only allows users to log on if the ID is known to the system and if password associated with ID is correct.

→ User can reveal their password to other either intentionally or accidentally.

→ Hacker are skillful at guessing passwords.

Data-Oriented access controls:-

→ Associate with each user, there can be a user profile that specifies permissible

operation and file accesses. (hammi profile py jo permission wala seen)

→ OS enforces these rules.

→ DBMS controls access to specific records or portion of records

Access Matrix :-

- **Subject**

An entity capable of accessing objects.

- **Object**

Anything to which access is controlled.

- **Access rights :-**

The way in which an object is accessed by a subject.

	File 1	File 2	File 3
User A	Own, R, W		Ownership, R, W
User B	R	own, R, W	W
User C	R, W	R	Own, R, W

Example of Access matrix:
control structure.

Access Control List :-

→ matrix decomposed by column.

→ For each object, an access control list gives user & their permitted access rights.

plain-text:-

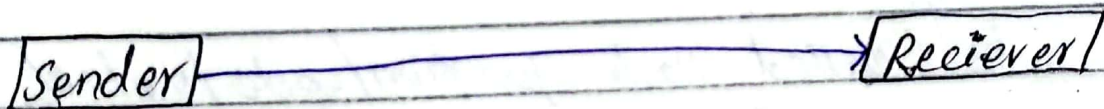
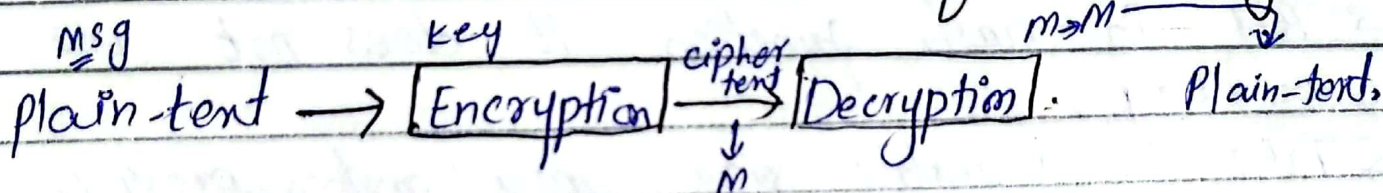
Everybody read it & understand.

Q Why we convert plain-text into cipher text.

→ We convert plain-text into cipher-text to achieve confidentiality.

→ CIA.

Q How to we achieve confidentiality?



Types of cryptography:-

Symmetric

- ↳ same key use
- ↳ The key which is use for encryption, the same key is used for decryption.

Asymmetric

- ↳ Different key use.
- ↳ one key is used for encryption/lock & different key is used for unlock/decryption.

Lec

Physical Security Issues:-

Unauthorized Access

Tailgating and piggybacking

Insider Threat

Physical assets theft

Vandalism & Sabotage

social engineering

Lack of surveillance

Emergency preparedness

Unauthorized Access:-

Unauthorized access is a significant concern in physical security. It can occur due to weaknesses in access control system, such as compromised, credential, unauthorized key duplication or exploiting vulnerabilities or exploiting in electronic access system.

Tailgating & Piggybacking:-

Tailgating refers to unauthorized individuals following closely behind an authorized person to gain entry into a secure system/area. Piggybacking on the other hand invokes unauthorized individuals exploiting the courtesy of the individuals.

authorized person by asking to be allowed into a secure area, Both practices undermine access control system & compromises the security of restricted area.

وہ لوگ جو اپنی position یا galat فائدہ اٹھاتے ہیں اور اس میں سے employ جو کہ جان بوجھ کر نقصان پہنچا سکتے ہیں۔



Insider Threat:-

Insider threats involves individuals who have unauthorized access to the facility but misuse their privilege for malicious purpose. This can include employee contracts, or vendors who may steal valuable assets. Insider can exploit their knowledge of security protocols, weaknesses in the system or their trusted position to carry out authorized activities.

وہ لوگ جن کو security کی knowledge ہے اور اس کو skill کو فائدہ استعمال کرتے system کو کمزور کرتے ہیں تاکہ کوئی بھی system کو easy access کر سکے۔

Physical Asset theft:-

ناکافی نگرانی یا ناکافی حفاظتی اقدامات اگر اچھے لگے نہ ہوتی چوری ہو سکتی ہے

The theft of physical assets such as equipment, inventory or valuable resources is a significant concern for organizations. Theft can occur due to insufficient security measures, inadequate surveillance, or gaps in inventory controls. It can result in financial losses, disruption of operation & compromised competitiveness.

جس کی وجہ سے آپ کے کاموں میں خلل آسکتا ہے اور نقصان ہو سکتا ہے۔

Vandalism & Sabotage

Physical security also addresses the protection against vandalism & sabotage, malicious individual may target facilities or assets to cause damage, disrupt operation or gain a competitive advantage. Vandalism can involve defacing or interfering with critical infrastructure or destroy system resources.

vandalism mean : توڑ پھوس
sabotage mean : تخریب کاری

Social Engineering

Social Engineering is a technique used by an attacker to trick a person into revealing sensitive information or performing an action that compromises the security of the organization. It involves manipulating a person's trust or fear to gain access to secure areas or systems.

Social engineering.

Physical security can be compromised through social engineering techniques, where individuals manipulate others into divulging sensitive information or providing access to secure areas.

Social Engineering tactics may include impersonation, deception to gain unauthorized entry or bypass security protocols.

or the issue security is the lack of camera

Lack of surveillance:-

Inadequate surveillance coverage including blind spots or gaps in camera placement, can limit the effectiveness of physical security. Without comprehensive monitoring & recording capabilities it becomes difficult to identify & investigate security incidents.

Emergency preparedness is an important issue in physical security. The lack of proper emergency preparedness.

Organization should have robust plans and protocols in place to respond to emergencies such as fire, natural disaster or security incidents.

Sec Personal Security.

Human are the weakest link in the security chain.

⇒ Job Description:-

- First step defining security need related to personal.
- Define the role to which an employee needs to be assigned.
- Define the type & extend of access the position require.

⇒ Separation of Duties:-

- Critical, significant & sensitive work task are divided among
- Several individual people
- Help protect against collusion.

⇒ Job Rotation:-

- Rotating employee among multiple job functions.
- Provide knowledge redundancy.

◦ Reduce risk of fraud, data modification, theft, misuse.

→ Cross-training:-

Employees are just prepared for multiple job position.
just helps on knowledge redundancy.

→ Employment Agreement:-

Employment agreement must be signed before job responsibilities are provided.

(Don't share personal data of Company).

◦ NDA:- Non disclosure agreement used to protect confidential agreement with in an organization.

NCA:- Non-Compete agreement used to prevent former employees to work for competitor.

Mandatory Vacations:-

Places a different employee helps detect fraud, abuse, negligence.

⇒ Employee Termination process:-

- Should take place with at least with eye witness.
- Once informed of termination all access (logical/physical) should be disable & the employee should be escorted out of office.
- Best time to terminated is middle of the week at the end of the shift.
- Before the employee is released, allow organization specific assets need to be collected.
- Exit interview should be conducted.

⇒ Employment candidate Screening

- Should be based on critically & sensitivity defined by the job description.
- Should be completed before a candidate is on boarded into the organization.
- Its an administrative control.
- BG, drug test, credit score, criminal record, education, professional experience.

Lecture:-

-: Information Security Policy :-

Policy:-

- Plan or course of actions as of a government, political party, or business, intended to influence & determine decision actions & other matters.
- Policies can be define a set of rules that guide any government or any organization.
- Security policies are established rules that provide guidance in the protection of an organization assets.
- Policies are written to support to mission, vision, & strategic planning of an organization.

Formate of policy:-

Singular Policy → ☐ Yes ☐ No

Consolidated Policy →

All in One Policy form	
☒	
☒	
☒	

→ Policy Hierarchy :-

→ Principle :-

Highest - level idea and values.

→ Policy :-

Highest - Level , mandatory statement.
all person have must
unique password → must

→ Standard :-

Prescribed level or criteria
→ 8-characters password special symbol.

→ Guideline :-

Best practices designed to achieve
policy objectives.
must follow the rules"

→ Baselines :-

Minimum configuration requirements
settings of organization ; password.

→ Procedure :-

Individual , discrete steps ;
step by step move by using
guideline & baseline.

→ Create policy :-
Identify the applicable, legal,
& regulatory requirements.

Steps:-

- ① Planning is required → for create policy.
- ② Align with Business & Legal Requirement → monitoring the activities
- ③ Audience Prospectives: → language is important to gain acceptance.
- ④ Consult external → consult the legal officer to communicate.
- ⑤ Bad approvals → need to submit to Board and approved these policy for board director.

→ Policy keywords:-

- ① must, Not must
- ② Recommended, should.

⇒ Scope of Create Policy:-

- The scope of Information security policy intends to all ~~infrast~~ ^{infrastructure} information & its operational activities including but not limited to.
- Records held by the college relating to school pupils, student, staff, visitors.
- Marketing plans, financial records & minutes.

Policy contents:-

- 1- Version History → Initial 1.0, ^{Next} version 1.1 version,
- 2- Introduction
- 3- Purpose → specify the intention of entire security policy
- 4- scope
- 5- History (1.0 Ranvir, 1.1 Prabh.)
- 6- Roles
- 7- Policy Definition
- 8- Policy exception
- 9- standards if we have
10. signer Authority

⇒ Security Policy:

These are must be follows:-

- Physical Security
- Access Control
- Network Security
- System Security
- Authorized security tools
- Auditing procedure.

Building ^{Physical} security policies:

Human threats:-

theft, destruction, damage and terrorism.

Building damage:-

fire, water damage, and toxic leak.

Natural disaster:-

flood, hurricanes and storms.

Infrastructure disruption:-

Loss of power of downed communication lines.

Equipment failure:-

Computer system, damages and network device failure.

: Building a security policy for Access Control:-

- Authentication User ID & password.
- Authentication model
- Implementation technologies and mechanism
- Access Control - determines who get the access.
- Authentication example - : User account creation, Deletion & validation
- manage user account password policies , manage password.

Building a security policy of Network security.

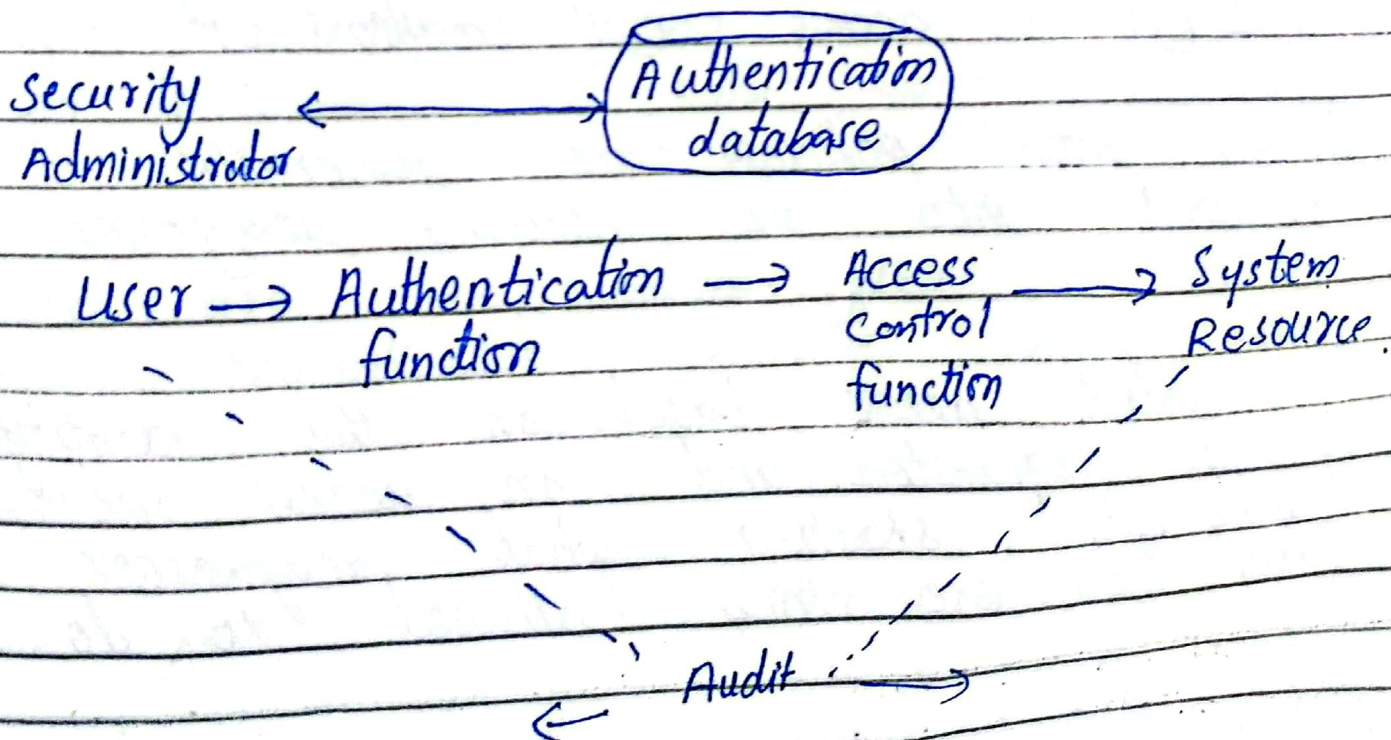
- Specific timeframes for changing password on the network device
- Use of secure network protocol.
- Firewalls at specific checkpoints in a network architecture.
- Use of authentication server to access network devices.

Topic: .. Access Control:

Access control as the process of ~~control~~ granting or denying specific requests to obtain and use information & related information processing systems, services, and enter specific physical facilities.

Access Control as the process of granting or denying specific requests to obtain and use information of related information processing services, and enter specific physical facilities.

Access Control implements a security policy that specifies who or what (e.g. in the case of a process) may have access to each specific system resources and the type of access that is permitted in each instance -



اس میں ہمیں یہ بتانا ہے کہ
person کا authorized ہے اور
access دیا
کر سکتا ہے۔

Kon sa person kasy
system ko access
kr raha hai or
kiya activity perform
kr raha ha.

An access control policy which can be
embadded in an authorization database,
dictates what type of access are
permitted under what circumstances
and by whom.

کس کو کون سے
ایک Person اگر اس کو access کرنا ہوگا۔
تو وہ record only ہی Enter کرے گا۔
ایک Person اگر اس کو enter کرنا ہوگا۔

کس conditions میں access دی جاتی ہے۔

Access control policies are generally
grouped into the following categories

Control access based on the identity
of the requested and on access rules
(authorization) starting what requester
use (or are not) allowed to do.

Termed discretionary because an entity might have access rights that permit the entity by its own volition, to enable another entity to access some resource.

اس میں owner policy کو set کرنے میں کون اسے access کرنے کا allow کیا کر سکتا ہے۔

Control access based on comparing security label (sensitive or critical system resource), with security clearness (which system entities are eligible to access contain certain resources)

ایک person کو Security clear access ملے گی۔ یہ اس کی اپنی willing پر مشتمل ہے گی۔ authorizer - ہوگا تو ہی - allow ہوگا۔ Government method اور army میں use کرتے ہیں۔

There are four main types of access Control organization typically choose the method that make the most sense based on their unique security & compliance requirement. The four access control models are.

organization چار methods میں سے کسی ایک کو choose کرتی ہے۔ ان کی requirement کو fulfill کرتی ہے۔

DAC (Discretionary Access Control)

MAC (Mandatory Access Control)

Role based access control (RBAC)

RBAC :-

RBAC grants access based on defined business function rather than the individual user's identity.

This widely used method is based on a complex combination of role assignments, authorization & permissions.

Organization کے آئندہ ان کی role کی مطابق access ہے۔

Access is based on a set of attributes and environmental conditions such as time of day & location, assigned to both user and resources.

Lecture:

Legal & Social Issues in IS

SPAM:-

Spamming is used of electronic message system to set unsolicited message (spam) specially advertising as well as sending message repeatedly on some site.

ہم کسی ویب سائٹ پر notification دے کر spam message کو اپنے folder میں آتے ہیں۔

Spam can be used to spread computer viruses, trojan horse or other malicious software.

Email Spam

Email spam is an unsolicited email that claims the prospect of the bargain or something for nothing.

Some spam message ask for business, other invite victims to a website with detailed pitch. Many individuals have lost their life saving due to their type of fraud.

Email spam is the form of email fraud.

{ help me in my business you won
so lac cash & gold; I need
a partner for my business etc. }

Don't click on any link in spam email.

Don't replay to the email or contact to sender in any way.

If you have click on the link in the email, do not support any information on the websites that may open.

Don't open any attachment that arrive with email.

Hacking

The person who is consistently engaging in hacking activity and has accepted hacking as a lifestyle & philosophy of their choice is called hacking.

Hacking is the practice of modifying the feature of a system in order to accomplish a goal outside of the creator original purpose.

Computer hacking is a most popular form of hacking now a day. Especially in a field of computer security but hacking exists in many other forms such as phone hacking, brain hacking etc and its not limited to either of them.

{ Hacking for business warfare
It is just a part of
business }

Viruses:-

A computer virus is a malware program that when executed, replicated by inserting copies of itself into other computer programs, data files or boot sector of a hard drive.

When this replication succeed the affected area are then said to be "infected".

جب کوئی unworked ← email, folder اور
 file آپ کو recieve ہو تو اس میں virus
 کے chances زیادہ ہوتے ہیں اور virus
 اپنی copy بنا کر آپ کے Comp کو
 affect کرتے ہیں اور پھر infect computers
 ہوتا ہے۔

Worm:-

A computer worm is a malware
 computer program that replicated
 itself in order to spread to
 other computers.

Often, it was computer network to
 spread itself relaying on security
 failure on targeted computers to
 access.

data files ← DVD ← CD ← through
 comp ← worm تو میں نے transfer
 spread ہوتا ہے۔

{ For stealing our personal information
 to access our computers }